

**ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ ОБРАЗОВАТЕЛЬНОЕ УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ
«САНКТ-ПЕТЕРБУРГСКИЙ НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ
УНИВЕРСИТЕТ ИНФОРМАЦИОННЫХ ТЕХНОЛОГИЙ,
МЕХАНИКИ И ОПТИКИ»**

Факультет безопасности информационных технологий

Дисциплина:

«Теория информационной безопасности и методология защиты информации»

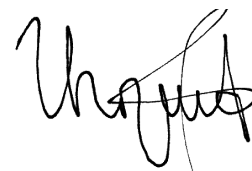
ОТЧЕТ ПО ЛАБОРАТОРНОЙ РАБОТЕ №1

«Исследование баз данных угроз и уязвимостей. Калькулятор уязвимостей»

Выполнил:

Студент гр. N3251

Агакарян Арам Арманович



(подпись)

Проверил:

Кондратенко Станислав Сергеевич

(отметка о выполнении)

(подпись)

Санкт-Петербург

2026 г.

СОДЕРЖАНИЕ

ВВЕДЕНИЕ.....	3
1 ИССЛЕДОВАНИЕ БАЗ ДАННЫХ УГРОЗ И УЯЗВИМОСТЕЙ.....	4
1.1 Банк данных угроз безопасности информации ФСТЭК России.....	4
1.2 CVE и National Vulnerability Database (NVD).....	6
1.3 Vulners.....	8
1.4 Exploit Database.....	9
1.5 CERT/CC Vulnerability Notes Database.....	11
1.6 Другие базы данных и сравнение рассмотренных источников.....	12
2 КАЛЬКУЛЯТОР CVSS. ОЦЕНКА ОПАСНОСТИ УЯЗВИМОСТЕЙ.....	14
2.1 Метрики CVSS v3.....	14
2.2 Оценка уязвимости по базовым метрикам.....	15
2.3 Оценка уязвимости по временным метрикам.....	16
2.4 Оценка уязвимости по контекстным метрикам.....	16
2.5 Отличия CVSS v4.0 от предыдущих версий.....	18
ЗАКЛЮЧЕНИЕ.....	21
СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ.....	22

ВВЕДЕНИЕ

Цель работы — получить знания и навыки работы с различными базами данных угроз и уязвимостей.

Для достижения поставленной цели необходимо решить следующие задачи:

- изучить обязательный материал для ознакомления;
- описать пять баз данных угроз и уязвимостей, привести примеры их интерфейса;
- решить задачи с калькулятором CVSS на вычисление опасности уязвимости по базовым, временным и контекстным метрикам;
- выяснить, чем версия CVSS 4.0 отличается от предыдущих.

Объектами исследования выступают банк данных угроз безопасности информации ФСТЭК России, базы данных CVE и NVD, агрегатор Vulners, архив эксплойтов Exploit Database и база уязвимостей CERT/CC, а также калькуляторы CVSS версий 3 и 4.

1 ИССЛЕДОВАНИЕ БАЗ ДАННЫХ УГРОЗ И УЯЗВИМОСТЕЙ

Уязвимость — недостаток (слабость) программного, программно-технического средства или информационной системы, который может быть использован для реализации угрозы безопасности информации. Угроза — совокупность условий и факторов, создающих потенциальную или реально существующую опасность нарушения безопасности информации. Базы данных угроз и уязвимостей позволяют единообразно идентифицировать уязвимости, быстро находить сведения о них (затронутые продукты, опасность, наличие эксплойта, способы устранения) и приоритизировать работы по их закрытию [3].

1.1 Банк данных угроз безопасности информации ФСТЭК России

Банк данных угроз безопасности информации (БДУ) создан ФСТЭК России совместно с ФАУ «ГНИИИ ПТЗИ ФСТЭК России» и работает с 2015 года. Это основной российский государственный источник сведений об уязвимостях: на него ссылаются нормативные документы ФСТЭК, его применяют при моделировании угроз по Методике оценки угроз безопасности информации (2021) и при оценке критичности уязвимостей по методике ФСТЭК 2022 года [2, 6].

Банк состоит из двух основных разделов:

- **перечень угроз** — угрозы с идентификаторами вида УБИ.001, УБИ.002 и так далее (на момент выполнения работы — 227 угроз). Для каждой угрозы указаны описание, источник угрозы, объект воздействия и последствия реализации: нарушение конфиденциальности, целостности или доступности;

- **перечень уязвимостей** — записи с идентификаторами вида BDU:ГТГГ-NNNNN (на момент выполнения работы — 96 144 записи). В карточке уязвимости приводятся наименование и описание, вендор, наименование и версия ПО, тип ПО, класс уязвимости, тип ошибки по классификации CWE, оценки по CVSS 2.0 и CVSS 3.1 с векторами, уровень опасности, возможные меры по устранению и ссылки на внешние источники.

Перечень уязвимостей с формой фильтрации приведён на рисунке 1.

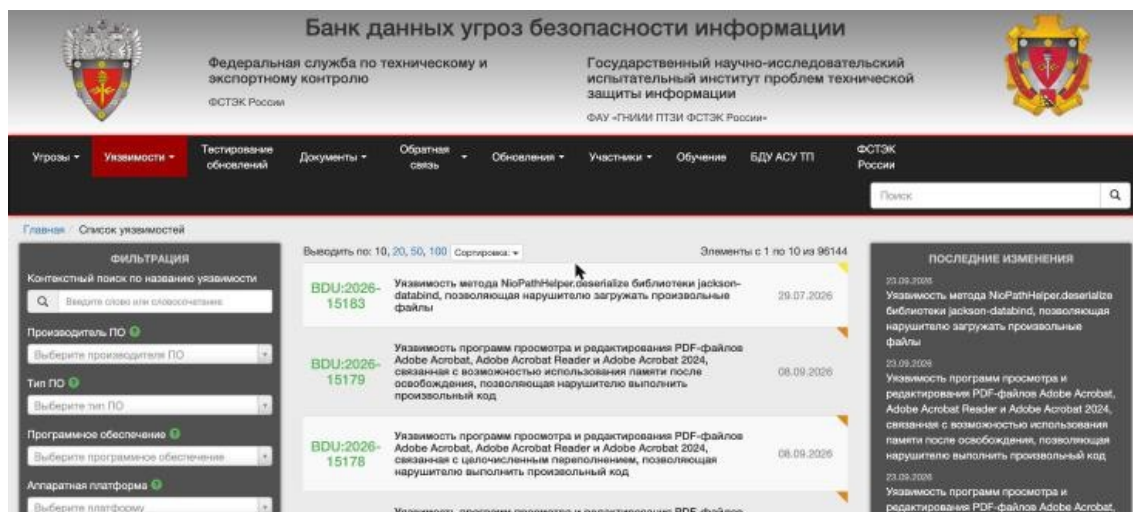


Рисунок 1 – Перечень уязвимостей в БДУ ФСТЭК России с формой фильтрации

Отдельного внимания заслуживают служебные поля карточки уязвимости, которые показаны на рисунке 2:

- **статус уязвимости** — «Подтверждена производителем», «Подтверждена в ходе исследований», «Потенциальная уязвимость»;
- **наличие эксплойта** — «Существует в открытом доступе», «Существует», «Данные уточняются»;
- **информация об устранении** — «Уязвимость устранена», «Информация об устранении отсутствует», «Данные уточняются»;
- **уровень опасности** по шкале: низкий (0,1–3,9), средний (4,0–6,9), высокий (7,0–9,9), критический (10,0). Эта шкала отличается от шкалы FIRST, где критический уровень начинается с 9,0.

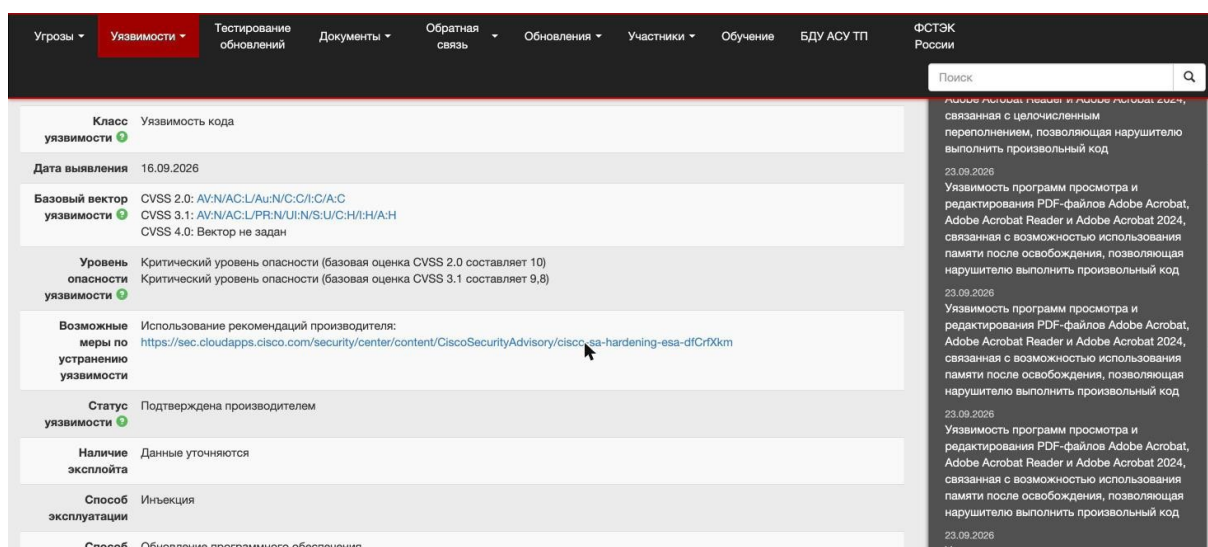


Рисунок 2 – Карточка уязвимости BDU:2026-15171: векторы CVSS, статус уязвимости и наличие эксплойта

Кроме того, на сайте доступны калькуляторы CVSS 2.0 и CVSS 3.0, раздел «Термины и определения», перечень мер защиты и сведения о программных продуктах, в том числе российских. Поиск возможен по наименованию, вендору, идентификатору, уровню опасности, дате и наличию эксплойта, а выгрузка — в форматах XLSX и XML. Недостатком является задержка появления записей относительно зарубежных источников, преимуществом — наличие отечественного ПО и сертифицированных средств защиты информации.

1.2 CVE и National Vulnerability Database (NVD)

Программа CVE (Common Vulnerabilities and Exposures) — это не база с подробным анализом, а реестр уникальных идентификаторов, ведущийся корпорацией MITRE с 1999 года. Идентификаторы вида CVE-ГГГГ-NNNN выдают уполномоченные организации — CNA (CVE Numbering Authorities): крупные вендоры, CERT-центры, исследовательские компании. Запись CVE содержит идентификатор, краткое описание и ссылки. Состояния записи: RESERVED — номер зарезервирован, детали не раскрыты; PUBLISHED — запись опубликована; REJECTED — запись отклонена как дубликат, ошибка или как не являющаяся уязвимостью. Для оспариваемых записей применяется пометка DISPUTED [8].

NVD — база Национального института стандартов и технологий США (NIST), синхронизированная с CVE и дополняющая записи сведениями: оценками CVSS версий 2, 3.x и 4.0 с векторами, классификацией CWE, перечнем уязвимых конфигураций в формате CPE, ссылками на исправления и эксплойты, отметкой о вхождении в каталог CISA KEV. Статусы записи: Received, Awaiting Analysis, Undergoing Analysis, Analyzed, Modified, Deferred, Rejected [9]. Форма поиска показана на рисунке 3.

С 15 апреля 2026 года NIST изменил модель работы: из-за роста числа регистрируемых уязвимостей от полного обогащения всех записей пришлось отказаться. Приоритет отдаётся уязвимостям из каталога CISA KEV, программному обеспечению, используемому в федеральных органах США, и ПО, отнесённому к критически важному; остальные записи переводятся в категорию «Lowest Priority — not scheduled for immediate enrichment» и не получают обогащение NIST в первоочередном порядке. Кроме того, NIST больше не формирует собственную оценку CVSS для тех уязвимостей, для которых оценку уже предоставила организация-CNA [14].

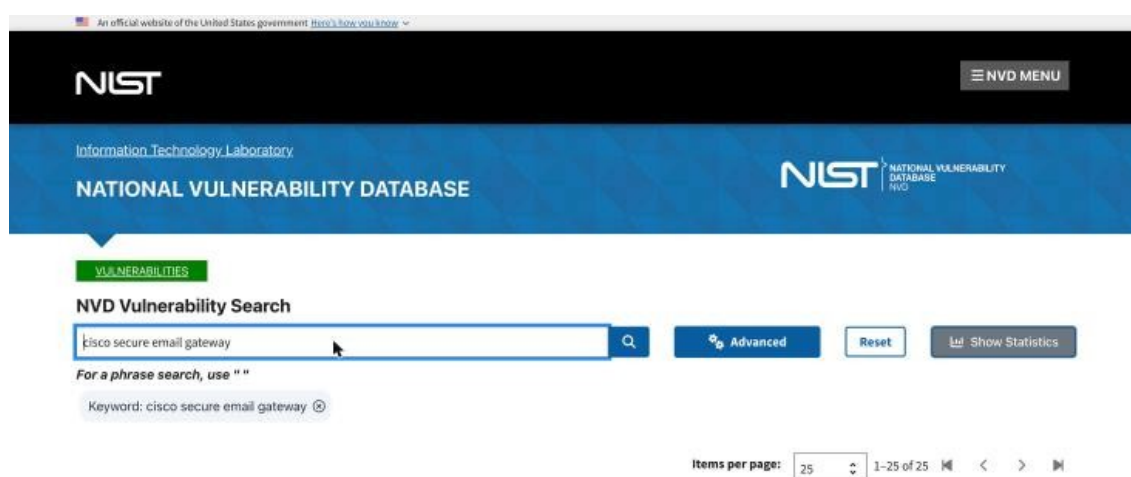


Рисунок 3 – Поиск уязвимостей на сайте NVD по ключевому слову

Описанная политика наглядно видна на рисунке 4, где приведена страница уязвимости CVE-2026-76461. По состоянию на 25.09.2026 оценка 9,8 (критический уровень) указана организацией-CNA (Cisco Systems), тогда как собственная оценка NIST отсутствует с пометкой «NVD assessment not yet provided», хотя запись опубликована 14.09.2026 и включена в каталог CISA KEV.

Это не ошибка и не следствие одного лишь отставания в анализе, накопившегося с 2024 года: по действующим с апреля 2026 года правилам NIST не дублирует собственной оценкой уже имеющуюся оценку CNA. Практический вывод: при работе с базами следует обращать внимание на источник оценки, поскольку многие агрегаторы показывают оценку CNA как оценку NVD.

unauthenticated, remote attacker to execute arbitrary commands with root privileges on the underlying operating system. This vulnerability is due to insufficient validation in the email parsing logic. An attacker could exploit this vulnerability by sending a crafted email message that contains malicious SQL statements through an affected device. A successful exploit could allow the attacker to execute arbitrary SQL statements, leading to command execution with root privileges on the underlying operating system.

CVE-2026-76461
NVD Published Date: Sep 14, 2026
NVD Last Modified: Sep 15, 2026
Source: Cisco Systems, Inc.

Metrics

CVSS Version 4.0 CVSS Version 3.x CVSS Version 2.0 SSVC

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:

**NIST: NVD**

Base Score: N/A

NVD assessment not yet provided.

**CNA: Cisco Systems, Inc.**

Base Score: 9.8 CRITICAL

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

References to Advisories, Solutions, and Tools

By selecting these links, you will be leaving NIST webspace. We have provided these links to other web sites because they may have information that would be of interest to you. No inferences should be drawn on account of other sites being referenced, or not, from this page. There may be other web sites that are more appropriate for your purpose. NIST does not necessarily endorse the views expressed, or concur with the facts presented on these sites. Further, NIST does not endorse any commercial products that may be mentioned on these sites. Please address comments about this page to nvd@nist.oov.

Рисунок 4 – Страница уязвимости CVE-2026-76461 в NVD: оценка CNA при отсутствующей оценке NVD

1.3 Vulners

Vulners — агрегатор, созданный русскоязычными специалистами по информационной безопасности. Он собирает и нормализует данные из сотен источников: NVD, бюллетеней вендоров (Microsoft, Red Hat, Debian, Ubuntu и других), БДУ ФСТЭК, Exploit-DB, Metasploit, Packet Storm, отчётов bug bounty и публикаций исследователей. Документы связаны между собой: по одному идентификатору CVE можно увидеть и описание, и патчи, и готовые эксплойты [4, 7].

Особенности базы: поиск с языком запросов в стиле Lucene, собственная оценка AI Score, учитывающая помимо CVSS реальную эксплуатируемость, отображение показателя EPSS, открытый API для интеграций, плагины для сканеров (Nmap-скрипт vulners, Burp Suite), агент аудита Linux-систем по списку установленных пакетов. Результат запроса «type:exploitdb AND cvss.score:[9 TO 10]» приведён на рисунке 5.

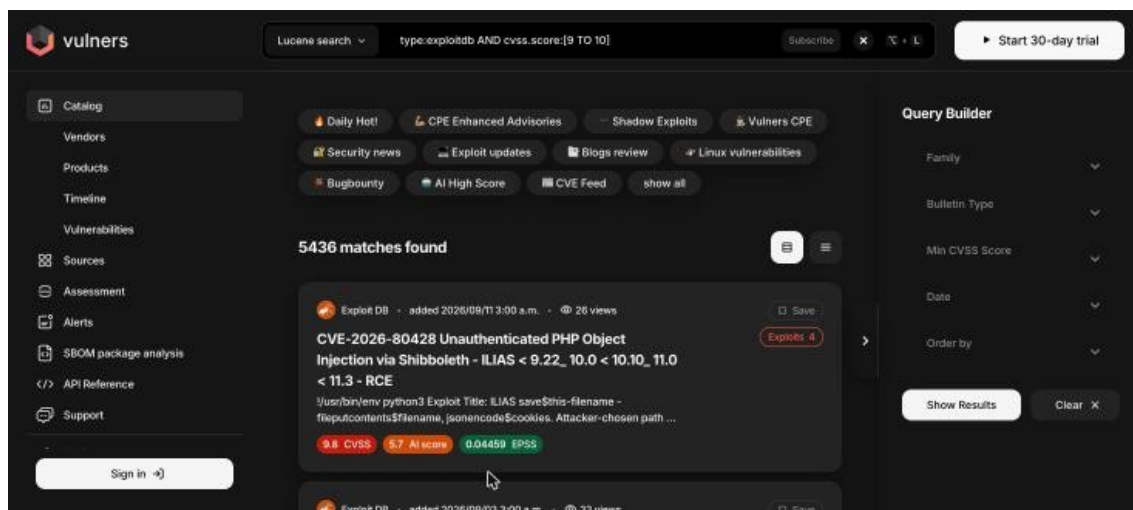


Рисунок 5 – Результаты поиска на vulners.com по запросу type:exploitdb AND cvss.score:[9 TO 10]

На рисунке 6 показана страница уязвимости CVE-2021-44228 (Log4Shell): видны оценки CVSS 2, CVSS 3.1, AI Score и EPSS, а также перечень связанных документов — эксплойтов, бюллетеней и публикаций.

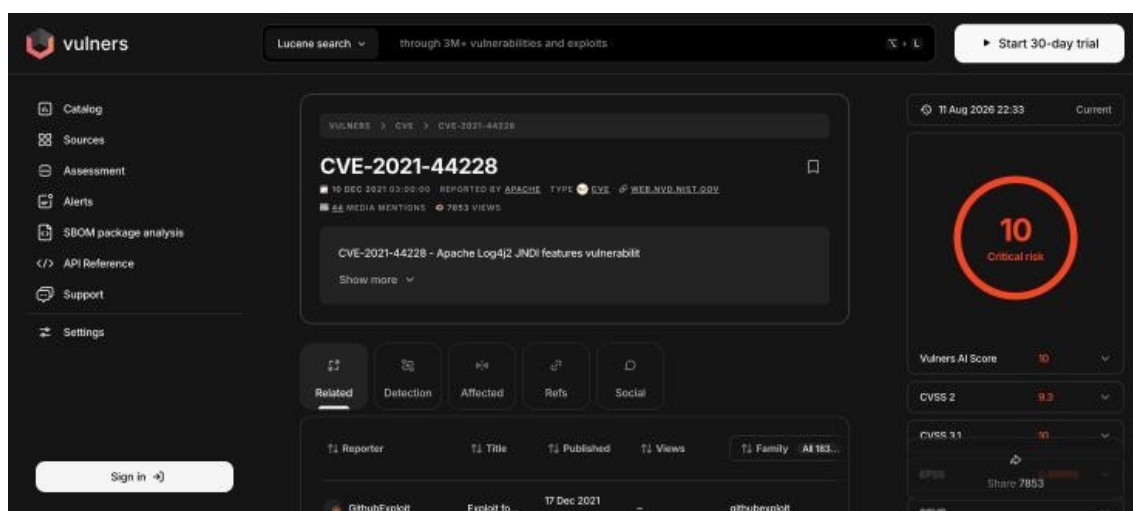


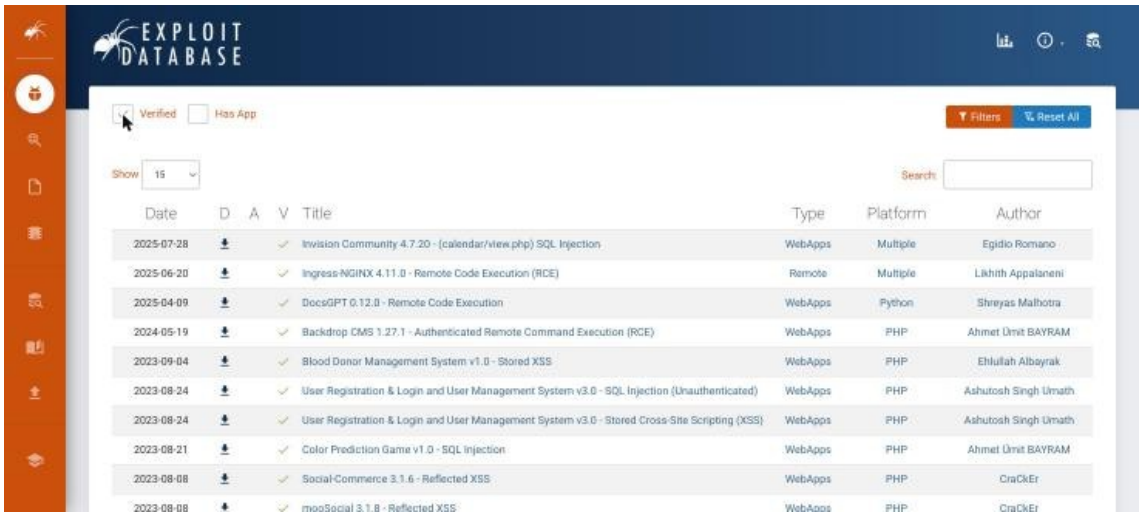
Рисунок 6 – Страница уязвимости CVE-2021-44228 (Log4Shell) в Vulners со связанными документами

1.4 Exploit Database

Exploit-DB — архив публичных эксплойтов и уязвимого программного обеспечения, поддерживаемый компанией OffSec (Offensive Security, разработчик Kali Linux). Записи имеют идентификатор EDB-ID; для каждой указаны автор, дата, тип (remote, local, webapps, DoS, shellcode), платформа, связанный идентификатор CVE и отметка Verified, означающая, что

работоспособность эксплойта проверена командой проекта. Часто прикладывается уязвимая версия приложения для воспроизведения.

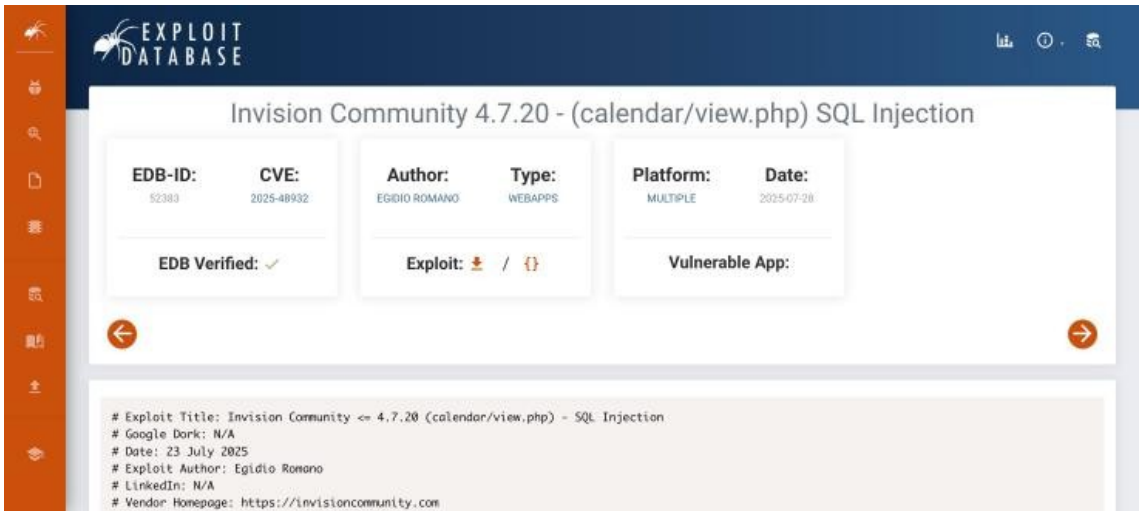
Дополнительные разделы базы: Google Hacking Database — набор поисковых запросов для обнаружения уязвимых и неправильно настроенных ресурсов, Papers и Shellcodes. Локальная копия базы входит в состав Kali Linux, поиск по ней выполняется утилитой searchsploit. В отличие от NVD и БДУ, Exploit-DB отвечает не на вопрос «насколько опасна уязвимость», а на вопрос «существует ли для неё рабочий эксплойт», что важно при приоритизации устранения [10]. Список эксплойтов с включённым фильтром Verified приведён на рисунке 7, карточка отдельного эксплойта — на рисунке 8.



The screenshot shows the Exploit-DB website interface. At the top, there's a navigation bar with the 'EXPLOIT DATABASE' logo and icons for user, search, and settings. Below the header, there are filters for 'Verified' (checked) and 'Has App'. A 'Show' dropdown is set to '15'. A search bar is on the right. The main content is a table of exploits.

Date	D	A	V	Title	Type	Platform	Author
2025-07-28	📄	👤	✓	Invision Community 4.7.20 - (calendar/view.php) SQL Injection	WebApps	Multiple	Egidio Romano
2025-06-20	📄	👤	✓	Ingress-NGINX 4.11.0 - Remote Code Execution (RCE)	Remote	Multiple	Likhith Appalaneni
2025-04-09	📄	👤	✓	DocsGPT 0.12.0 - Remote Code Execution	WebApps	Python	Shreyas Malhotra
2024-05-19	📄	👤	✓	Backdrop CMS 1.27.1 - Authenticated Remote Command Execution (RCE)	WebApps	PHP	Ahmet Umit BAYRAM
2023-09-04	📄	👤	✓	Blood Donor Management System v1.0 - Stored XSS	WebApps	PHP	Ehulalah Albayrak
2023-08-24	📄	👤	✓	User Registration & Login and User Management System v3.0 - SQL Injection (Unauthenticated)	WebApps	PHP	Ashutosh Singh Umash
2023-08-24	📄	👤	✓	User Registration & Login and User Management System v3.0 - Stored Cross-Site Scripting (XSS)	WebApps	PHP	Ashutosh Singh Umash
2023-08-21	📄	👤	✓	Color Prediction Game v1.0 - SQL Injection	WebApps	PHP	Ahmet Umit BAYRAM
2023-08-08	📄	👤	✓	Social-Commerce 3.1.6 - Reflected XSS	WebApps	PHP	CraCkEr
2023-08-08	📄	👤	✓	mooSocial 3.1.8 - Reflected XSS	WebApps	PHP	CraCkEr

Рисунок 7 – Список эксплойтов Exploit-DB с включённым фильтром Verified



The screenshot shows the detailed view of an exploit on the Exploit-DB website. The title is 'Invision Community 4.7.20 - (calendar/view.php) SQL Injection'. Below the title, there are several fields: EDB-ID (52383), CVE (2025-48932), Author (EGIDIO ROMANO), Type (WEBAPPS), Platform (MULTIPLE), and Date (2025-07-28). There are also checkboxes for 'EDB Verified' (checked) and 'Vulnerable App'. Below these fields, there is a section for the exploit details, including the exploit title, Google Dork, date, author, linked in, and vendor homepage.

Invision Community 4.7.20 - (calendar/view.php) SQL Injection

EDB-ID: 52383 CVE: 2025-48932 Author: EGIDIO ROMANO Type: WEBAPPS Platform: MULTIPLE Date: 2025-07-28

EDB Verified: ✓ Exploit: 📄 / 📄 Vulnerable App:

Exploit Title: Invision Community <= 4.7.20 (calendar/view.php) - SQL Injection
Google Dork: N/A
Date: 23 July 2025
Exploit Author: Egidio Romano
LinkedIn: N/A
Vendor Homepage: https://invisioncommunity.com

Рисунок 8 – Карточка эксплойта EDB-ID 52383 с привязанным идентификатором CVE

1.5 CERT/CC Vulnerability Notes Database

CERT Coordination Center — первый в мире центр реагирования на компьютерные инциденты, созданный в 1988 году в Институте программной инженерии (SEI) Университета Карнеги — Меллон после эпидемии червя Морриса. CERT/CC занимается координированным раскрытием уязвимостей: получает сообщения от исследователей, связывается с вендорами и публикует бюллетени; для координации используется платформа VINCE.

База Vulnerability Notes содержит записи с идентификаторами вида VU#NNNNNN (рисунок 9). Её особенность — раздел Vendor Information со статусом каждого затронутого производителя: Affected, Not Affected, Unknown, а также датами уведомления и ответа (рисунок 10). Записей в базе значительно меньше, чем в NVD, но они, как правило, затрагивают сразу многих вендоров: протоколы, библиотеки, прошивки.



Рисунок 9 – Список Vulnerability Notes на сайте CERT/CC

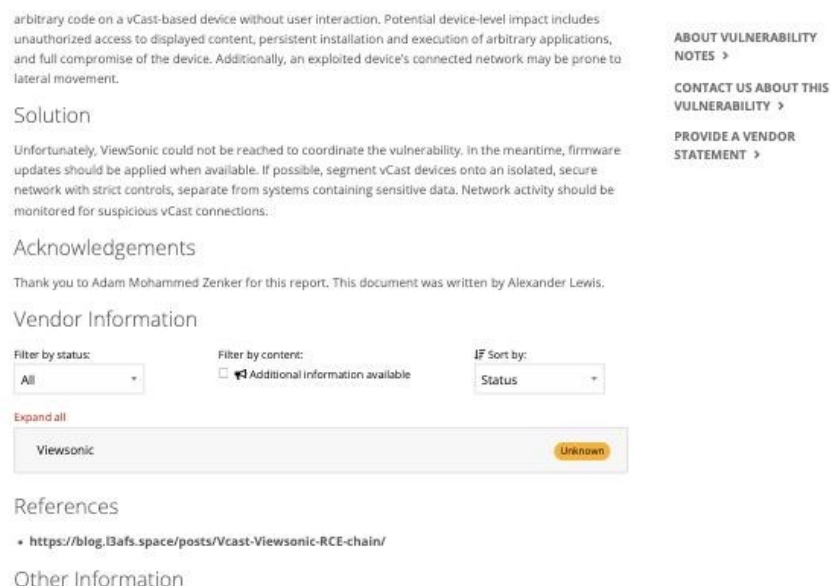


Рисунок 10 – Запись VU#234131 с разделом Vendor Information и статусом вендора

1.6 Другие базы данных и сравнение рассмотренных источников

Помимо рассмотренных подробно, в задании упомянут ряд других источников:

- **JVN и JVN iPedia** (Япония, JPCERT/CC и IPA) — идентификаторы вида JVN# и JVNDB-ГГГГ-NNNNNN, широко представлено японское программное обеспечение;

- **CNNVD** (Китай, CNITSEC) — государственная база КНР с идентификаторами вида CNNVD-ГГГГММ-NNN;

- **IBM X-Force Exchange** — платформа threat intelligence компании IBM: уязвимости, индикаторы компрометации, репутация IP-адресов и URL, оценка бизнес-последствий эксплуатации;

- **Secunia** — датская компания, в 2015 году поглощённая Flexera; её бюллетени доступны в составе коммерческих продуктов Flexera;

- **SecurityFocus** и рассылка **BugTraq** — историческая база с идентификаторами BID; в 2021 году сайт прекратил работу, поэтому источник представляет главным образом исторический интерес;

- **exploit.in** — русскоязычный форум, а не база уязвимостей; используется киберпреступной средой и интересен лишь как объект мониторинга угроз.

Сводное сравнение рассмотренных баз приведено в таблице 1.

Таблица 1 – Сравнение баз данных угроз и уязвимостей

База	Владелец	Идентификатор	Оценка опасности	Главная ценность
БДУ ФСТЭК	ФСТЭК России	BDU:ГТГГ- NNNNN, УБИ.NNN	CVSS 2.0 и 3.1	Нормативный статус в РФ, перечень угроз, отечественное ПО
CVE / NVD	MITRE / NIST (США)	CVE-ГТГГ- NNNN	CVSS 2.0, 3.x, 4.0	Единый идентификатор, CPE, CWE, открытый API
Vulners	Vulners (частная)	Идентификаторы источников	CVSS, AI Score, EPSS	Агрегация сотен источников, связь уязвимости и эксплойта
Exploit-DB	OffSec	EDB-ID	Нет (ссылка на CVE)	Проверенные публичные эксплойты, GHDB, searchsploit
CERT/CC	SEI CMU (США)	VU#NNNNNN	CVSS (не всегда)	Координированное раскрытие, статусы вендоров

2 КАЛЬКУЛЯТОР CVSS. ОЦЕНКА ОПАСНОСТИ УЯЗВИМОСТЕЙ

Для количественной оценки опасности уязвимостей используется открытый стандарт CVSS (Common Vulnerability Scoring System). Он разработан по инициативе Национального консультативного совета по инфраструктуре США (NIAC), первая версия опубликована в 2005 году, дальнейшее развитие стандарта ведёт организация FIRST. Хронология версий: CVSS v1 — 2005 год, v2 — 2007 год, v3.0 — 2015 год, v3.1 — 2019 год, v4.0 — 1 ноября 2023 года [1, 12].

2.1 Метрики CVSS v3

Оценка CVSS v3 складывается из трёх групп метрик.

– **Базовые метрики (Base)** описывают неизменные свойства уязвимости. Метрики эксплуатируемости: вектор атаки AV (сетевой N, смежная сеть A, локальный L, физический P), сложность атаки AC (низкая L, высокая H), уровень привилегий PR (не требуются N, низкий L, высокий H), взаимодействие с пользователем UI (требуется R, не требуется N). Влияние на другие компоненты системы описывает метрика Score (не изменяется U, изменяется C). Метрики воздействия: конфиденциальность C, целостность I, доступность A со значениями «высокое» H, «низкое» L, «отсутствует» N.

– **Временные метрики (Temporal)** изменяются со временем: доступность средств эксплуатации E (не определено X, высокая H, есть сценарий F, есть PoC-код P, теоретическая U), доступность средств устранения RL (X, недоступны U, рекомендации W, временное T, официальное O), степень доверия к информации об уязвимости RC (X, подтверждена C, достоверные отчёты R, отчёты U).

– **Контекстные метрики (Environmental)** учитывают конкретную среду эксплуатации: требования к конфиденциальности CR, целостности IR и доступности AR (низкие L = 0,5; средние M = 1; высокие H = 1,5), а также модифицированные базовые метрики MAV, MAC, MPR, MUI, MS, MC, MI, MA.

Далее по тексту используется обозначение CVSS v3, как назван калькулятор ФСТЭК России и как указано в задании; расчёты выполнены по формулам версии 3.1, которые в рассмотренных задачах дают тот же результат, что и версия

3.0. Числовые коэффициенты базовых метрик: AV: N = 0,85, A = 0,62, L = 0,55, P = 0,2; AC: L = 0,77, H = 0,44; PR: N = 0,85, L = 0,62 (0,68 при S:C), H = 0,27 (0,5 при S:C); UI: N = 0,85, R = 0,62; C, I, A: H = 0,56, L = 0,22, N = 0. Расчёты ниже выполнены в калькуляторе CVSS v3 ФСТЭК России [11] и проверены по формулам спецификации [12].

2.2 Оценка уязвимости по базовым метрикам

Задача (вариант г): атака низкой сложности будет проводиться на сетевой уровень системы, при этом оказывается влияние на другие компоненты системы. Атака приводит к нарушению конфиденциальности высокого уровня и доступности низкого уровня. Взаимодействие с пользователем не требуется, а уровень привилегий — низкий.

Решение. Вектор CVSS v3: AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:N/A:L.

- $ISS = 1 - (1 - 0,56) \cdot (1 - 0) \cdot (1 - 0,22) = 1 - 0,3432 = 0,6568$;
- $Impact \text{ (при S:C)} = 7,52 \cdot (0,6568 - 0,029) - 3,25 \cdot (0,6568 - 0,02)^{15} \approx 4,72$;
- $Exploitability = 8,22 \cdot 0,85 \cdot 0,77 \cdot 0,68 \cdot 0,85 \approx 3,11$;
- $Base = RoundUp(\min(1,08 \cdot (4,72 + 3,11); 10)) = RoundUp(8,45) = 8,5$.

Результат расчёта в калькуляторе приведён на рисунке 11.

Банк данных угроз безопасности информации

Федеральная служба по техническому и экспортному контролю
ФСТЭК России

Государственный научно-исследовательский испытательный институт проблем технической защиты информации
ФАН «ГНИИ ПТЗИ ФСТЭК России»

Угрозы - Уязвимости - Тестирование обновлений - Документы - Обратная связь - Обновления - Участники - Обучение - БДУ АСУ ТП - ФСТЭК России

Поиск

Главная - Калькулятор CVSS v3

Вектор CVSS v3: (AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:N/A:L)

Базовые метрики **8.5**

Базовая оценка (BS): 8.5

Вектор атаки (AV): Сетевой (N) | Сложная сеть (A) | Локальный (L) | Физический (P)

Сложность атаки (AC): Высокая (H) | Низкая (L)

Уровень привилегий (PR): Высокий (H) | Низкий (L) | Не требуется (N)

Взаимодействие с пользователем (UI): Требуется (Y) | Не требуется (N)

Влияние на другие компоненты системы (S): Не оказывает (N) | Оказывает (Y)

Влияние на конфиденциальность (C): Не оказывает (N) | Низкое (L) | Высокое (H)

Влияние на целостность (I): Не оказывает (N) | Низкое (L) | Высокое (H)

Влияние на доступность (A): Не оказывает (N) | Низкое (L) | Высокое (H)

Рисунок 11 – Калькулятор CVSS v3, базовые метрики (вариант г)

Ответ: 8,5 — высокий уровень опасности.

2.3 Оценка уязвимости по временным метрикам

Задача (вариант б): предполагается, что есть сценарий для средств эксплуатации, не определена доступность средств устранения и подтверждена степень доверия к источнику информации об уязвимости.

Решение. В качестве базовой используется оценка из подраздела 2.2 (8,5). Вектор временных метрик: E:F/RL:X/RC:C.

– Temporal = RoundUp(Base · E · RL · RC) = RoundUp(8,5 · 0,97 · 1 · 1) = RoundUp(8,245) = 8,3.

Результат расчёта приведён на рисунке 12.

The screenshot shows the 'Уязвимости' (Vulnerabilities) section of a web application. The main heading is 'Калькулятор CVSS v3'. Below it, the CVSS vector is displayed: 'AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:N/A:L/E:F/RL:X/RC:C'. The 'Базовые метрики' (Base Metrics) section shows a score of 8.5. The 'Временные метрики' (Temporal Metrics) section shows a score of 8.3. The 'Временная оценка (TS): 8.3' is highlighted in green. The 'Доступность средств эксплуатации (E):' section shows 'Есть сценарий (F)' selected. The 'Доступность средств устранения (RL):' section shows 'Не определено (X)' selected. The 'Степень доверия к информации об уязвимости (RC):' section shows 'Подтверждена (C)' selected. The 'Контекстные метрики' (Contextual Metrics) section is empty. At the bottom, the status bar shows 'Угрозы: 227', 'Уязвимости: 96144', and 'Последнее обновление: 23.09.2020'. The footer mentions '© ФАУ «ГНИИИ ПТЗИ ФСТЭК России»'.

Рисунок 12 – Калькулятор CVSS v3, временные метрики (вариант б)

Ответ: 8,3 — высокий уровень опасности. Наличие работающего сценария эксплуатации почти не снижает оценку, а отсутствие сведений об исправлении не снижает её вовсе.

2.4 Оценка уязвимости по контекстным метрикам

Задача (вариант а): к уровню обеспечения КЦД заданы низкие требования, однако влияние на них оказывается высоким. При этом проводится атака низкой сложности на локальный уровень системы. Уровень привилегий в данном случае — высокий, взаимодействия с пользователем не происходит. Оказывается ли влияние на другие компоненты системы — неизвестно.

Решение. Базовый вектор: AV:L/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H, базовая оценка 6,7 (рисунок 13). Базовая метрика Score не допускает значения «не определено», поэтому для расчёта принято значение S:U (влияние на другие компоненты не подтверждено), а неопределённость условия отражена в модифицированных метриках: MS и остальные модифицированные метрики оставлены в значении «не определено» (X). Контекстный вектор: CR:L/IR:L/AR:L.

Угрозы ▾ Уязвимости ▾ Тестирование обновлений ▾ Документы ▾ Обратная связь ▾ Обновления ▾ Участники ▾ Обучение ▾ БДУ АСУ ТП ▾ ФСТЭК России

Поиск 🔍

Базовые метрики ⓘ 6.7 AV:L/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H

Базовая оценка (BS): 6.7

Вектор атаки (AV):
☐ Сетевой (N) ☐ Смежная сеть (A) ☒ Локальный (L) ☐ Физический (P)

Сложность атаки (AC):
☐ Высокая (H) ☒ Низкая (L)

Уровень привилегий (PR):
☒ Высокий (H) ☐ Низкий (L) ☐ Не требуется (N)

Взаимодействие с пользователем (UI):
☐ Требуется (R) ☒ Не требуется (N)

Влияние на другие компоненты системы (S):
☒ Не оказывает (U) ☐ Оказывает (C)

Влияние на конфиденциальность (C):
☐ Не оказывает (N) ☐ Низкое (L) ☒ Высокое (H)

Влияние на целостность (I):
☐ Не оказывает (N) ☐ Низкое (L) ☒ Высокое (H)

Влияние на доступность (A):
☐ Не оказывает (N) ☐ Низкое (L) ☒ Высокое (H)

Временные метрики ⓘ

Контекстные метрики ⓘ

Угрозы: 227 Уязвимости: 96144 Последнее обновление: 23.09.2026

© ФАУ «ГНИИИ ПТЭИ ФСТЭК России»

Рисунок 13 – Калькулятор CVSS v3, базовые метрики варианта а (базовая оценка 6,7)

- $MISS = \min(1 - (1 - 0,5 \cdot 0,56)^3; 0,915) = 1 - 0,72^3 = 0,6268;$
- Modified Impact (при S:U) = $6,42 \cdot 0,6268 \approx 4,02;$
- Modified Exploitability = $8,22 \cdot 0,55 \cdot 0,77 \cdot 0,27 \cdot 0,85 \approx 0,80;$
- Environmental = $\text{RoundUp}(\min(4,02 + 0,80; 10)) = \text{RoundUp}(4,82) = 4,9.$

Результат расчёта контекстных метрик приведён на рисунке 14.

Угрозы | **Уязвимости** | Тестирование обновлений | Документы | Обратная связь | Обновления | Участники | Обучение | БДУ АСУ ТП | ФСТЭК России

Главная / Калькулятор CVSS v3

Вектор CVSS v3: (AV:L/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H/E:X/RL:X/RC:L/IR:L/AR:L)

Базовые метрики 6,7 AV:L/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H

Временные метрики 6,7 E:X/RL:X/RC:X

Контекстные метрики 4,9 CRL:IR:L/AR:L

Контекстная оценка (ES): 4.9

Требования к конфиденциальности (CR):
☐ Не определено (X) ☒ Низкие (L) ☐ Средние (M) ☐ Высокие (H)

Требования к целостности (IR):
☐ Не определено (X) ☒ Низкие (L) ☐ Средние (M) ☐ Высокие (H)

Требования к доступности (AR):
☐ Не определено (X) ☒ Низкие (L) ☐ Средние (M) ☐ Высокие (H)

Вектор атаки (корр.) (MAV):
☒ Не определено (X) ☐ Сетевой (N) ☐ Смежная сеть (A) ☐ Локальный (L) ☐ Физический (P)

Сложность атаки (корр.) (MAC):
☒ Не определено (X) ☐ Высокая (H) ☐ Низкая (L)

Уровень привилегий (корр.) (MPR):
☒ Не определено (X) ☐ Высокий (H) ☐ Низкий (L) ☐ Не требуется (N)

Взаимодействие с пользователем (корр.) (MUJ):
☒ Не определено (X) ☐ Требуется (R) ☐ Не требуется (N)

Влияние на другие компоненты системы (корр.) (MS):

Рисунок 14 – Калькулятор CVSS v3, контекстные метрики (вариант а)

Ответ: 4,9 — средний уровень опасности. Низкие требования к конфиденциальности, целостности и доступности в конкретной системе снижают значимость уязвимости с 6,7 до 4,9, хотя сама уязвимость при этом не изменилась.

Сводные результаты расчётов приведены в таблице 2.

Таблица 2 – Результаты оценки уязвимостей по CVSS v3

Задача	Вектор	Оценка
Базовые метрики, вариант г	AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:N/A:L	8,5 (высокий)
Временные метрики, вариант б	.../E:F/RL:X/RC:C	8,3 (высокий)
Контекстные метрики, вариант а	AV:L/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:H/CR:L/IR:L/AR:L	4,9 (средний)

2.5 Отличия CVSS v4.0 от предыдущих версий

Версия CVSS 4.0 опубликована организацией FIRST 1 ноября 2023 года. Общий вид официального калькулятора этой версии приведён на рисунке 15.

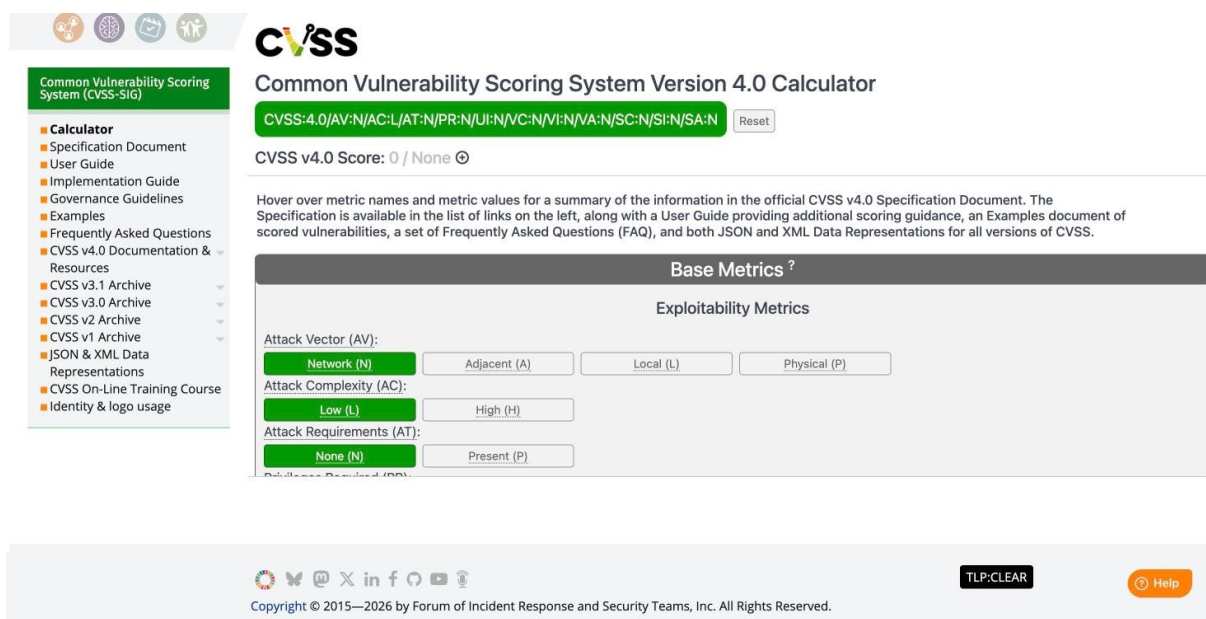


Рисунок 15 – Калькулятор CVSS v4.0 на сайте FIRST

Основные изменения по сравнению с версией 3 состоят в следующем [5, 12, 13]:

- изменён состав групп метрик: Base, Threat (вместо Temporal), Environmental и новая группа Supplemental. Введены обозначения итоговой оценки CVSS-B, CVSS-BT, CVSS-BE и CVSS-BTE в зависимости от учтённых групп, что подчёркивает: базовая оценка не является оценкой риска;
- группа Threat упрощена — в ней осталась только метрика Exploit Maturity (Attacked, PoC, Unreported), а метрики Remediation Level и Report Confidence исключены;
- добавлена базовая метрика Attack Requirements (AT), описывающая предварительные условия в развёртывании цели, например состояние гонки или определённую конфигурацию; ранее такие условия смешивались со сложностью атаки;
- метрика User Interaction получила три значения: None, Passive и Active;
- метрика Score удалена, вместо неё воздействие оценивается отдельно для уязвимой системы (VC, VI, VA) и для последующих систем (SC, SI, SA);
- добавлена группа дополнительных метрик Supplemental, не влияющих на оценку: Safety, Automatable, Recovery, Value Density, Vulnerability Response Effort, Provider Urgency. В контекстной группе появилась возможность указать

влияние на безопасность людей (MSI:S, MSA:S), что важно для АСУ ТП, медицинской техники и устройств интернета вещей;

– изменён способ расчёта: вместо формулы с коэффициентами применяются макровекторы — классы эквивалентности, оценки которых определены экспертами, с интерполяцией внутри класса. Такой подход введён для более детального распределения итоговых оценок по различным комбинациям метрик.

Сравнительная характеристика версий приведена в таблице 3.

Таблица 3 – Сравнение CVSS v3 и CVSS v4

Характеристика	CVSS v3	CVSS v4
Группы метрик	Базовые, временные, контекстные	Base, Threat, Environmental, Supplemental
Влияние на другие компоненты	Метрика Score: изменяется или нет	Раздельная оценка уязвимой (VC, VI, VA) и последующих систем (SC, SI, SA)
Сложность атаки	Одна метрика AC	Разделена на AC и Attack Requirements (AT)
Взаимодействие с пользователем	Два значения: требуется, не требуется	Три значения: None, Passive, Active
Временные метрики	E, RL, RC	Только Exploit Maturity
Учёт безопасности людей	Не предусмотрен	Метрика Safety, значения MSI:S и MSA:S
Способ расчёта	Формулы с весовыми коэффициентами	Макровекторы (классы эквивалентности) с интерполяцией

ЗАКЛЮЧЕНИЕ

В ходе выполнения лабораторной работы были решены поставленные задачи: изучен обязательный материал, описаны пять баз данных угроз и уязвимостей, решены задачи с калькулятором CVSS и рассмотрены отличия версии 4.0 от предыдущих.

Рассмотренные базы различаются назначением. Программа CVE обеспечивает единую идентификацию уязвимостей, NVD и БДУ ФСТЭК России дают анализ и оценку опасности, причём БДУ имеет нормативное значение в Российской Федерации и дополнительно содержит перечень угроз. Exploit-DB показывает наличие реальных эксплойтов, CERT/CC — статус исправлений у производителей, а Vulners объединяет сведения из сотен источников в одном месте. Ни одна база не является полной: пример уязвимости CVE-2026-76461, для которой оценка NVD отсутствует, показывает, что сведения необходимо сверять по нескольким источникам, обращая внимание на статус записи, наличие эксплойта и информацию об устранении.

Освоен расчёт оценки опасности по CVSS v3. Базовая оценка для варианта г составила 8,5 (высокий уровень), временная для варианта б — 8,3 (высокий уровень), контекстная для варианта а — 4,9 (средний уровень) при базовой оценке 6,7. Расчёты показали, что временные метрики способны только снижать итоговую оценку, тогда как контекстные метрики могут как снижать её, так и повышать в зависимости от требований к конфиденциальности, целостности и доступности в конкретной системе.

Изучены отличия CVSS 4.0: отказ от метрики Score, введение метрики Attack Requirements и группы Supplemental, упрощение группы Threat и переход к расчёту по макровекторам. Эти изменения направлены на более детальное представление характеристик уязвимости и условий её эксплуатации; при этом сама по себе оценка CVSS не является оценкой риска, на чём отдельно акцентирует внимание FIRST. На практике в российских и зарубежных базах пока преобладают оценки версии 3.

СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ

1. Оценка уязвимостей CVSS 3.0 // Habr URL: <https://habr.com/ru/companies/pt/articles/266485/> (дата обращения: 25.09.2026).
2. Проблемы действующей методики определения актуальных угроз от ФСТЭК // Habr URL: <https://habr.com/ru/companies/ic-dv/articles/453756/> (дата обращения: 25.09.2026).
3. Меряем уязвимости: классификаторы и метрики компьютерных брешей // Хакер URL: <https://хакер.ru/2009/05/15/48221/> (дата обращения: 25.09.2026).
4. Vulners — Гугл для хакера. Как устроен лучший поисковик по уязвимостям и как им пользоваться // Habr URL: <https://habr.com/ru/companies/xakep/articles/305262/> (дата обращения: 25.09.2026).
5. Сравнение CVSS v3.1 и v4.0 // Habr URL: <https://habr.com/ru/companies/tomhunter/articles/754812/> (дата обращения: 25.09.2026).
6. Банк данных угроз безопасности информации // ФСТЭК России URL: <https://bdu.fstec.ru/> (дата обращения: 25.09.2026).
7. All-in-one vulnerability intelligence // Vulners URL: <https://vulners.com/> (дата обращения: 25.09.2026).
8. CVE Program Mission // CVE URL: <https://www.cve.org/> (дата обращения: 25.09.2026).
9. National Vulnerability Database // NIST URL: <https://nvd.nist.gov/> (дата обращения: 25.09.2026).
10. Exploit Database // OffSec URL: <https://www.exploit-db.com/> (дата обращения: 25.09.2026).
11. Калькулятор CVSS V3 // ФСТЭК России URL: <https://bdu.fstec.ru/calcv3> (дата обращения: 25.09.2026).
12. Common Vulnerability Scoring System version 4.0: Specification Document // FIRST URL: <https://www.first.org/cvss/specification-document> (дата обращения: 25.09.2026).

13. Vulnerability Notes Database // CERT Coordination Center URL: <https://www.kb.cert.org/vuls/> (дата обращения: 25.09.2026).

14. NIST Updates NVD Operations to Address Record CVE Growth // NIST URL: <https://www.nist.gov/itl/nvd> (дата обращения: 25.09.2026).